



Chuyên Đề 1 - tương đối ổn

VKU_Đồ án chuyên ngành 1 (Trường Đại học Công nghệ Thông tin và Truyền thông Việt - Hàn)



Scan to open on Studeersnel

**TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ
TRUYỀN THÔNG VIỆT – HÀN
KHOA KỸ THUẬT MÁY TÍNH & ĐIỆN TỬ**



**CHUYÊN ĐỀ 1
BẢO MẬT HẠ TẦNG MẠNG VÀ GIAO THỨC ĐỊNH
TUYỂN INTERNET**

**ĐỀ TÀI: TRIỂN KHAI TẤN CÔNG ARP VÀ
PHƯƠNG ÁN PHÒNG CHỐNG**

Sinh viên thực hiện	: HUỠNH VĨNH VINH	MSV: 21IT392
	: LÊ NGUYỄN WIN HỘI	MSV: 21IT350
	: NGUYỄN TRẦN TẤN TÀI	MSV: 21IT648
	: PHẠM ĐẠNG THÁI BẢO	MSV: 21IT530
Lớp	: 21NS	
Giảng viên hướng dẫn	: KS. NGUYỄN VĂN BÌNH	
	: TS. ĐẠNG QUANG HIỂN	

Đà Nẵng, tháng 12 năm 2023

**TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ
TRUYỀN THÔNG VIỆT – HÀN
KHOA KỸ THUẬT MÁY TÍNH & ĐIỆN TỬ**



**CHUYÊN ĐỀ 1
BẢO MẬT HẠ TẦNG MẠNG VÀ GIAO THỨC ĐỊNH
TUYỂN INTERNET**

**ĐỀ TÀI: TRIỂN KHAI TÂN CÔNG ARP VÀ
PHƯƠNG ÁN PHÒNG CHỐNG**

Sinh viên thực hiện	: HUỖNH VĨNH VINH	MSV: 21IT392
	: LÊ NGUYỄN WIN HỘI	MSV: 21IT350
	: NGUYỄN TRẦN TẤN TÀI	MSV: 21IT648
	: PHẠM ĐẶNG THÁI BẢO	MSV: 21IT530
Lớp	: 21NS	
Giảng viên hướng dẫn	: KS. NGUYỄN VĂN BÌNH	
	: TS. ĐẶNG QUANG HIỂN	

Đà Nẵng, tháng 12 năm 2023

This image shows a full page of white paper with horizontal dashed lines, typical of primary-ruled notebook paper. The lines are evenly spaced and run across the width of the page. There are no margins, text, or other markings on the paper.

LỜI CẢM ƠN

Để hoàn thành chuyên đề này trước tiên chúng em xin gửi đến KS. Nguyễn Văn Bình và TS. Đặng Quang Hiền người trực tiếp hướng dẫn môn học lời cảm ơn sâu sắc nhất.

Cảm ơn Thầy đã quan tâm và hướng dẫn, định hướng cho chúng em về hướng đi và phát triển của đề tài, cũng như cung cấp kiến thức về lý thuyết để thực hiện sản phẩm.

Vì khả năng sinh viên còn hạn chế, trong quá trình học tập, hoàn thiện báo cáo đồ án này chúng em không tránh khỏi những sai sót, kính mong nhận được những ý kiến đóng góp và chỉ bảo tận tình từ giảng viên hướng dẫn.

Cuối cùng chúng em kính chúc Thầy dồi dào sức khỏe và đạt được nhiều thành công tốt đẹp trong công việc.

Nhóm em xin chân thành cảm ơn!

Sinh viên

MỤC LỤC

DANH MỤC CÁC BẢNG

Trang

No table of figures entries found.

DANH MỤC HÌNH

Trang

No table of figures entries found.

DANH MỤC CỤM TỪ VIẾT TẮT

STT	Cụm từ	Viết tắt
1	IPS	Intrusion Prevention System
2	IDS	Intrusion Detection System
3	HIDS	Host Intrusion Detection System
4	NIDS	Network Intrusion Detection System

MỞ ĐẦU

Trong thời đại ngày nay, khi mạng internet trở thành một phần không thể thiếu trong đời sống và công việc, vấn đề bảo mật mạng trở nên ngày càng quan trọng. Một trong những thách thức đối mặt là tấn công ARP (Address Resolution Protocol), một phương pháp thường xuyên được kẻ tấn công sử dụng để chiếm địa chỉ mạng và thực hiện các hành động không đều đặn trong mạng nội bộ.

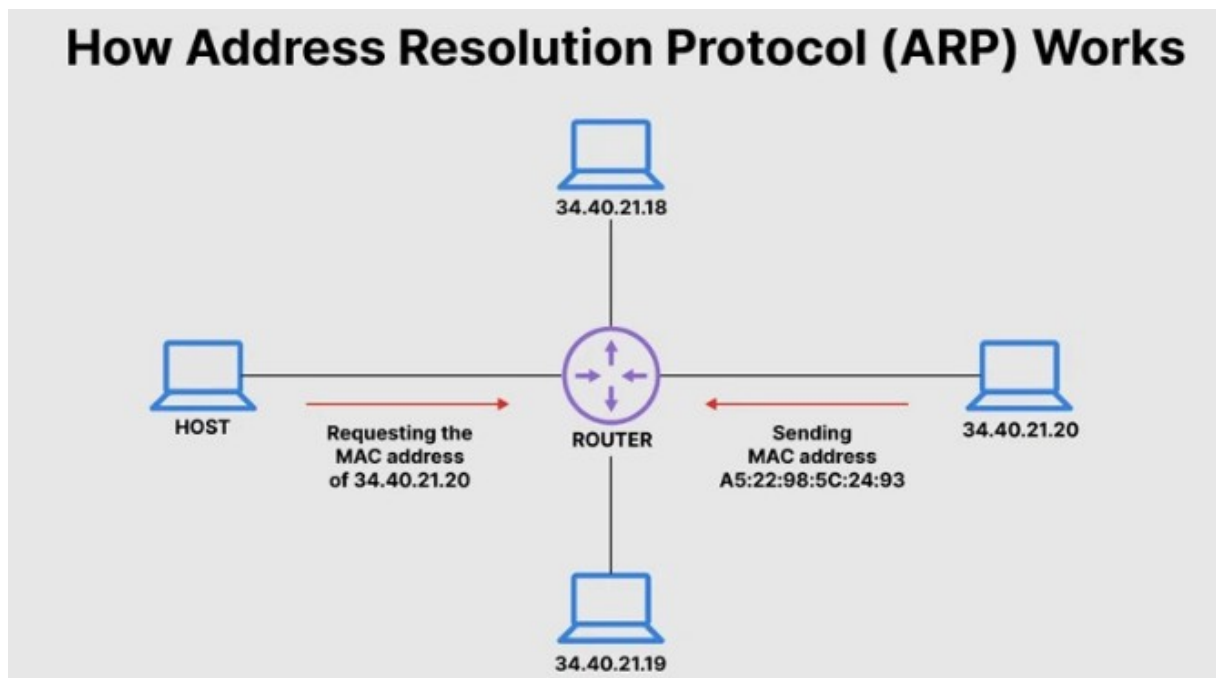
ARP là giao thức quan trọng giữa lớp mạng và lớp liên kết dữ liệu trong mô hình OSI, đảm bảo sự tương ứng giữa địa chỉ IP và địa chỉ MAC. Tuy nhiên, sự thiếu hụt bảo mật trong giao thức này mở ra khả năng cho tấn công ARP Spoofing, nơi mà kẻ tấn công có thể lừa đảo và chiếm địa chỉ IP của một máy tính, tạo điều kiện cho các hành động xâm nhập.

Chính vì vậy, nghiên cứu và hiểu rõ về cách thức tấn công ARP, cũng như xây dựng các biện pháp phòng chống là cực kỳ quan trọng để bảo vệ tính toàn vẹn và an toàn của mạng. Trong báo cáo này, chúng tôi sẽ đi sâu vào phân tích cách thức tấn công ARP, xác định mục tiêu và hậu quả của nó, cũng như trình bày các biện pháp phòng chống hiệu quả.

CHƯƠNG 1: TỔNG QUAN VỀ ARP (Address Resolution Protocol)

1.1 Khái niệm về ARP (Address Resolution Protocol)

Giao thức giải quyết địa chỉ (ARP - Address Resolution Protocol) là một giao thức mạng được áp dụng để xác định địa chỉ phần cứng, cụ thể là địa chỉ MAC (Media Access Control), của một thiết bị từ địa chỉ IP nguồn. Nó thường được sử dụng khi một thiết bị muốn liên lạc với các thiết bị khác trong phạm vi mạng cục bộ. Ví dụ, trong mạng Ethernet, hệ thống cần biết địa chỉ vật lý trước khi gửi các gói tin dữ liệu.



Thiết bị gửi thông điệp ARP nhằm chuyển đổi địa chỉ IP thành địa chỉ MAC. Trong quá trình này, thiết bị gửi một yêu cầu ARP chứa địa chỉ IP của thiết bị đích. Tất cả các thiết bị trong mạng local sẽ nhận thấy thông điệp này. Tuy nhiên, chỉ thiết bị có địa chỉ IP được yêu cầu mới có thể phản hồi với thông điệp chứa địa chỉ MAC của nó. Khi đó, thiết bị gửi yêu cầu sẽ có đủ thông tin cần thiết để gửi gói tin đến thiết bị đích.

1.2 Lịch sử và mục đích của ARP

Giao thức ARP đã xuất hiện và phát triển từ đầu những năm 1980 với vai trò là một giao thức quản lý việc dịch địa chỉ chung cho các mạng IP. Ngoài việc được triển khai rộng rãi trên Ethernet và WiFi, ARP cũng đã được áp dụng cho nhiều nền tảng khác như ATM, Token Ring và các loại mạng vật lý khác.



Đặc tính của ARP cho phép mạng quản lý các kết nối độc lập với từng thiết bị vật lý cụ thể được kết nối vào mạng. Điều này giúp cho giao thức Internet hoạt động hiệu quả hơn, vì nó không cần phải tự quản lý các địa chỉ của thiết bị phần cứng và mạng vật lý.

Những thông tin vừa rồi đã giúp ta nắm bắt rõ hơn về lịch sử và mục đích của giao thức ARP là gì trong mạng. Từ việc hiểu cách hoạt động, các dạng giao thức và tầm quan trọng của ARP, chúng ta nhận thấy vai trò quan trọng mà nó đóng trong việc kết nối thiết bị mạng thông qua ánh xạ giữa địa chỉ IP và địa chỉ MAC. Hiểu biết về ARP không chỉ giúp cải thiện quản lý mạng mà còn đóng vai trò quan trọng trong việc duy trì và bảo vệ hệ thống mạng hiện đại trong thời đại công nghệ ngày càng phát triển.

1.3 Các loại ARP

Hiện tại, giao thức ARP bao gồm bốn loại chính:

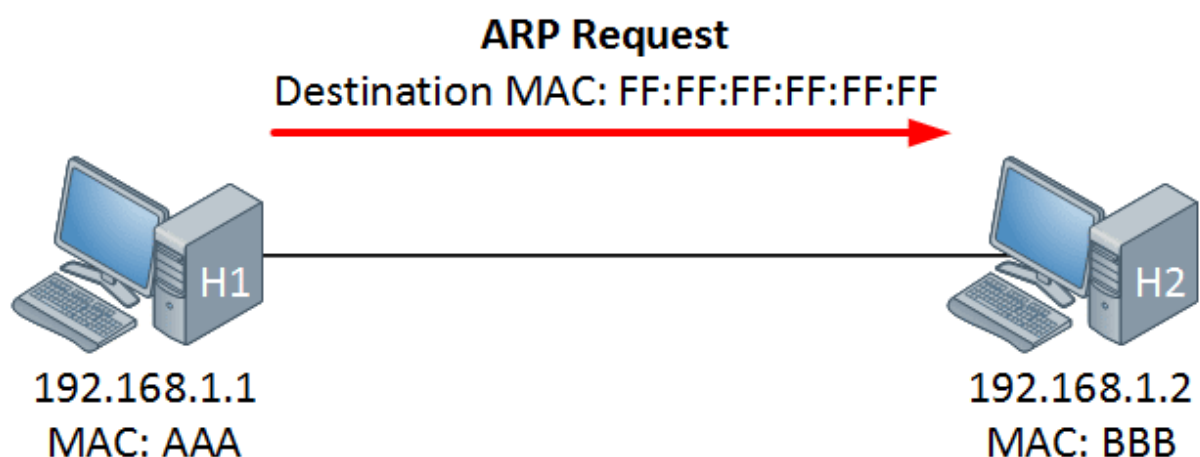


- **Proxy ARP:** Được thiết kế cho các thiết bị nội mạng và có phạm vi hoạt động cục bộ. Proxy ARP yêu cầu các thiết bị **Proxy** trong mạng phải phản hồi cho các yêu cầu ARP không chứa địa chỉ IP nằm trong mạng đó. Nó được sử dụng để xác định vị trí đích cho lưu lượng truy cập và cung cấp địa chỉ MAC của chính nó để sử dụng làm đích.
- **Gratuitous ARP:** Tương tự các quy trình thông thường nhưng thực hiện trên máy chủ, đây là một loại yêu cầu khác của host. Loại yêu cầu này giúp xác định các địa chỉ IP trùng lặp. Gratuitous ARP không gửi yêu cầu dịch hay thực hiện ARP request từ IP sang MAC.
- **Reverse ARP:** Được sử dụng trong hệ thống client trong mạng LAN để yêu cầu địa chỉ IPv4 từ bảng ARP của router. Máy chủ không thể tự nhận diện địa chỉ IP, nhưng có thể sử dụng Reverse ARP để xác định địa chỉ của chính nó. Quản trị viên tạo bảng trong gateway hoặc **router** để xác định địa chỉ MAC tới IP.
- **Inverse ARP:** Phổ biến trong các rơ-le frame của mạng ATM, Inverse ARP dùng để tìm địa chỉ IP của các node từ địa chỉ lớp liên kết dữ liệu. Nó thu thập địa chỉ mạch ảo ở lớp 2 từ việc signal của Layer 2.

1.4 Cách ARP hoạt động

Quá trình hoạt động của ARP bắt đầu khi một thiết bị nguồn trong mạng IP cần gửi một gói tin IP. Đầu tiên, cần xác định xem địa chỉ IP đích của gói tin có thuộc mạng nội bộ của thiết bị hay không. Nếu đúng, gói tin sẽ được gửi trực tiếp đến thiết bị đích.

Trường hợp địa chỉ IP đích nằm trên mạng khác, thiết bị cần chuyển gói tin tới router trong mạng nội bộ để router tiến hành chuyển tiếp gói tin. Trong việc gửi gói tin trong cùng mạng, Switch sẽ đóng vai trò dựa trên địa chỉ MAC. Sau khi gói tin được đóng gói hoàn chỉnh, quá trình phân giải địa chỉ ARP sẽ được thực hiện trước khi gói tin được chuyển đi.



Các hệ điều hành trong mạng IPv4 đều duy trì một bộ nhớ cache ARP. Khi cần thực hiện yêu cầu gửi gói tin đến một máy chủ khác trong mạng LAN, máy chủ sẽ sử dụng địa chỉ MAC. Trước khi thực hiện việc này, quá trình kiểm tra cache sẽ được thực hiện bởi ARP để kiểm tra xem bản dịch địa chỉ MAC đã có sẵn hay chưa.

Nói chung, ARP là một quá trình hai chiều request/response giữa các thiết bị nhằm xác định địa chỉ phần cứng từ địa chỉ IP nguồn. Thiết bị nguồn sử dụng request bằng cách

gửi một bản tin local broadcast trên toàn mạng. Thiết bị đích sẽ response thông qua một bản tin unicast để trả lời thiết bị nguồn.

Từ thông tin vừa cung cấp, chúng ta đã có cái nhìn tổng quan về cách hoạt động và tầm quan trọng của ARP là gì trong môi trường mạng.

1.5 Mối quan hệ của ARP với DHCP và DNS

ARP liên kết địa chỉ MAC tĩnh của thiết bị vật lý với địa chỉ IP động. Do đó, một số công nghệ mạng khác cũng có các liên kết tương tự đối với ARP và IP, như sau:

Để bảo vệ quyền riêng tư và đảm bảo an ninh cho người dùng, địa chỉ IP thường thay đổi đều đặn. Tuy nhiên, việc thay đổi này không được thực hiện ngẫu nhiên, mà tuân theo quy tắc nhất định nhằm ngăn chặn việc hai máy nhận cùng hai địa chỉ IP. Quy tắc này được gọi là DHCP - Dynamic Host Configuration Protocol hay còn được biết đến như Giao thức Cấu hình Máy chủ Động.

Khi người dùng muốn tìm kiếm thông tin trên Internet, họ thường sử dụng các ký tự. Trái lại, máy tính sử dụng địa chỉ IP khó nhớ để kết nối với tên miền hoặc máy chủ. Để đưa hai yếu tố này lại gần nhau, hệ thống phân giải tên miền (DNS - Domain Name System) ra đời. DNS chính là công cụ dùng để dịch địa chỉ IP thành tên miền và ngược lại, tạo điều kiện cho việc kết nối hiệu quả giữa hai yếu tố này.

CHƯƠNG 2: TẤN CÔNG ARP VÀ PHƯƠNG PHÁP PHÒNG CHỐNG

2.1 Khái quát về tấn công ARP

Tấn công ARP (Address Resolution Protocol) là một phương thức tấn công trong lĩnh vực bảo mật mạng, nơi kẻ tấn công lợi dụng yếu điểm trong giao thức ARP để thực hiện các hành động xâm nhập vào mạng nội bộ. Giao thức ARP được sử dụng để ánh xạ địa chỉ IP sang địa chỉ MAC trong mạng TCP/IP. Tấn công ARP thường liên quan đến việc làm giả mạo thông tin địa chỉ MAC trong gói tin ARP để tạo ra sự hiểu lầm trong bảng ARP của các thiết bị mạng khác.

Cơ bản, tấn công ARP thường diễn ra như sau:

- **Gửi Gói Tin ARP Spoofing:** Kẻ tấn công gửi các gói tin ARP được làm giả mạo, thông báo rằng địa chỉ MAC của một địa chỉ IP đã thay đổi. Gói tin này thường chứa thông tin giả mạo về địa chỉ MAC của kẻ tấn công và địa chỉ IP của nạn nhân.
- **Lừa Đảo Bảng ARP:** Các thiết bị mạng trong mạng nội bộ cập nhật bảng ARP của mình theo thông báo giả mạo. Do đó, chúng tin rằng địa chỉ IP đã được liên kết với địa chỉ MAC của kẻ tấn công.
- **Chuyển Hướng Lưu Lượng Mạng:** Khi bảng ARP được lừa đảo, lưu lượng mạng tới địa chỉ IP của nạn nhân bây giờ sẽ được chuyển hướng tới địa chỉ MAC của kẻ tấn công.

2.2 Mục tiêu của tấn công ARP

Tấn công ARP (Address Resolution Protocol) là một kỹ thuật thường được kẻ tấn công sử dụng để chiếm địa chỉ mạng và thực hiện các hành động xâm nhập vào mạng nội bộ. Dưới đây là một số mục tiêu chính của tấn công ARP:

- **Lấy Điều Khiển Trong Mạng:** Một trong những mục tiêu chính của tấn công ARP là lấy điều khiển hoặc kiểm soát trong mạng nội bộ. Khi kẻ tấn công chiếm địa chỉ IP của một máy tính, họ có thể chuyển hướng lưu lượng mạng đến máy tính của mình, tạo điều kiện cho việc theo dõi và can thiệp vào thông tin mạng.
- **Thực Hiện Cuộc Tấn Công Man-in-the-Middle (MITM):** Tấn công ARP thường là phương tiện để thực hiện cuộc tấn công Man-in-the-Middle, nơi mà kẻ tấn công đặt mình giữa hai bên giao tiếp. Điều này cho phép họ theo dõi và thậm chí là thay đổi thông tin được truyền tải giữa các thiết bị trong mạng.
- **Đánh Cắp Thông Tin Nhạy Cảm:** Khi kẻ tấn công có thể chiếm địa chỉ IP của máy tính nạn nhân, họ có thể thực hiện các cuộc tấn công nhằm đánh cắp thông tin nhạy cảm như tên đăng nhập, mật khẩu, thông tin tài khoản ngân hàng, và các dữ liệu cá nhân khác.

- **Phá Hoại Tính Toàn Vẹn của Mạng:** Bằng cách thực hiện tấn công ARP, kẻ tấn công có thể gây phá hoại tính toàn vẹn của mạng. Họ có thể thực hiện các cuộc tấn công phá hủy dữ liệu, thay đổi thông tin quan trọng hoặc ngăn chặn truy cập vào các nguồn tài nguyên mạng.
- **Tạo Lợi Ích Của Riêng Mình:** Mục tiêu cuối cùng của tấn công ARP có thể là tạo lợi ích cá nhân cho kẻ tấn công. Điều này có thể bao gồm việc sử dụng thông tin thu thập được để tống tiền, bán thông tin cá nhân, hoặc thậm chí thực hiện các hành động đàm phán xấu.

Tóm lại, tấn công ARP không chỉ là một cơ hội cho kẻ tấn công để chiếm địa chỉ mạng, mà còn là cánh cửa mở ra nhiều khả năng xâm nhập và tạo ra những hậu quả nghiêm trọng cho tính bảo mật của mạng. Việc hiểu rõ mục tiêu của tấn công này là quan trọng để phát triển và triển khai các biện pháp bảo mật hiệu quả

2.3 Đặc điểm của tấn công ARP

Tấn công ARP không chỉ là một phương pháp xâm nhập thông thường mà còn là một chiến lược tinh vi mà kẻ tấn công thường sử dụng để đạt được mục tiêu của mình trong môi trường mạng. Dưới đây là một số đặc điểm quan trọng của tấn công ARP và mục tiêu mà nó hướng đến:

- **Lợi Ích Kiểm Soát Đối Tượng:** Mục tiêu chính của tấn công ARP là đạt được sự kiểm soát đối tượng trong mạng. Kẻ tấn công muốn chiếm địa chỉ IP của một máy tính cụ thể để từ đó có thể kiểm soát và theo dõi hoạt động của máy tính đó.
- **Khả Năng Đánh Cắp Thông Tin Đăng Nhập:** Khi kẻ tấn công chiếm địa chỉ IP, họ có thể chủ động đánh cắp thông tin đăng nhập của nạn nhân. Điều này bao gồm cả tên đăng nhập và mật khẩu, mở ra cánh cửa cho việc xâm nhập vào các hệ thống và dịch vụ mà nạn nhân đang sử dụng.
- **Tấn Công Man-in-the-Middle và Hiệu Ứng Trung Gian:** Tấn công ARP thường đi kèm với mục tiêu triển khai cuộc tấn công Man-in-the-Middle. Khi kẻ tấn công có thể chiếm địa chỉ IP, họ có thể chuyển tiếp lưu lượng mạng giữa nạn nhân và các điểm đích, tạo điều kiện cho việc theo dõi và thậm chí là thay đổi thông tin truyền tải.
- **Thực Hiện Các Cuộc Tấn Công Khác:** Một khi đã kiểm soát được máy tính nạn nhân, kẻ tấn công có thể sử dụng nó làm điểm xuất phát cho các cuộc tấn công khác. Điều này có thể bao gồm việc thực hiện quét mạng, triển khai mã độc, hoặc thậm chí làm gián đoạn dịch vụ (DoS) đối với các nguồn tài nguyên mạng.
- **Nguy Cơ Cho An Ninh Mạng Toàn Cầu:** Tấn công ARP có thể có tác động lớn đến tính bảo mật mạng toàn cầu. Khi kẻ tấn công chiếm địa chỉ IP trong mạng nội bộ, họ có thể sử dụng nó để tiến xa, thậm chí xâm nhập vào các hệ thống mạng toàn cầu và thực hiện các cuộc tấn công lớn hơn.
- **Tính Linh Hoạt và Khả Năng Tấn Công Từ Xa:** Tấn công ARP không bị giới hạn bởi địa lý. Kẻ tấn công có thể thực hiện nó từ xa thông qua Internet, điều này tăng đáng kể độ nguy hiểm và tính linh hoạt của cuộc tấn công.

Tóm lại, tấn công ARP không chỉ đơn giản là việc chiếm địa chỉ IP mà còn mục tiêu đến việc kiểm soát và lợi dụng mạng nạn nhân để thực hiện nhiều cuộc tấn công khác nhau. Sự linh hoạt và khả năng tác động rộng lớn của nó đặt ra một thách thức đáng kể đối với bảo mật mạng.

2.4 Tấn công ARP

2.4.1 Tìm hiểu về giao thức ARP và cơ chế hoạt động

Mỗi một thiết bị trong mạng(máy tính router,) đều được nhận diện dưới hai dạng địa chỉ:

- Địa chỉ logic: phụ thuộc vào cấu trúc của từng mạng con và có thể thay đổi
- Địa chỉ vật lý (MAC address), là địa chỉ được nhà sản xuất ghi card mạng nằm bên trong thiết bị, không thể thay đổi

Để 1 thiết bị, cụ thể là một máy tính trong một mạng máy tính có thể truyền và nhận dữ liệu thì nó phải được gán 1 địa chỉ IP và nó phải cho các thiết bị khác biết địa chỉ MAC của nó

Như vậy ARP là một giao thức nằm trong tầng LINK-LAYER trong mô hình 4 tầng Internet protocol suite. Giúp phân giải địa chỉ IP thành địa chỉ MAC, giúp tìm ra máy tính sẽ nhận/ hoặc đã gửi 1 gói tin đến/ hoặc đi.

Giao thức ARP có 4 gói tin:

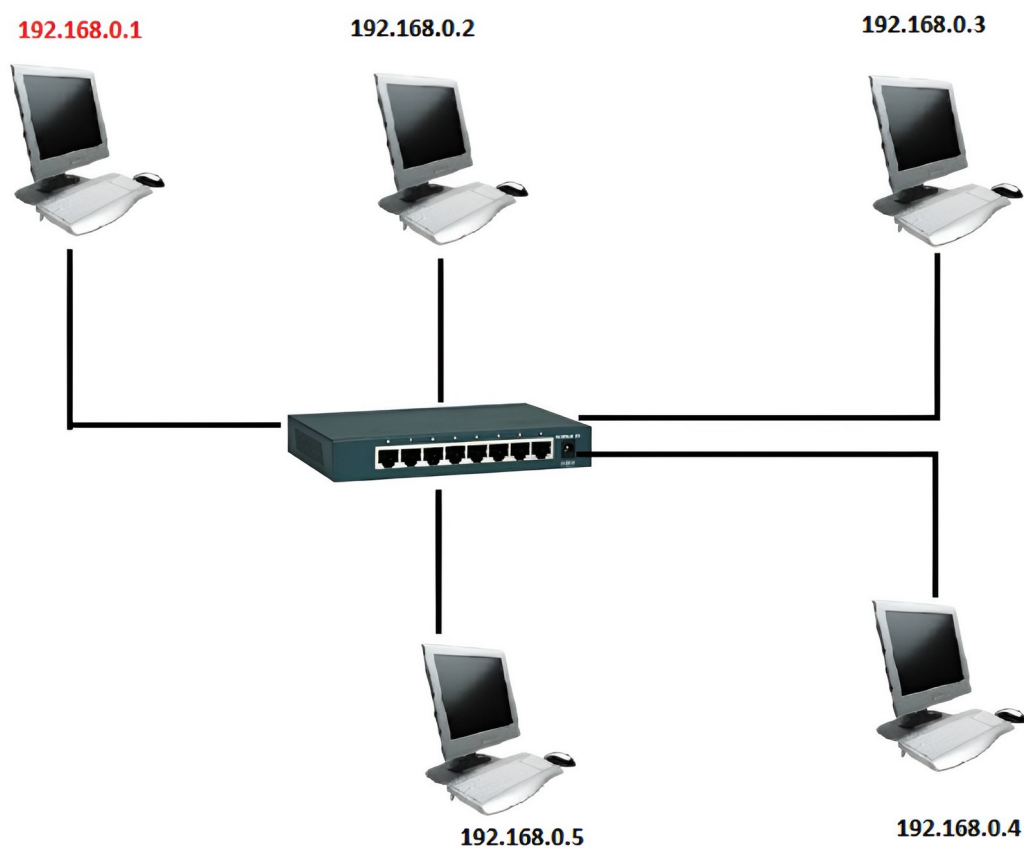
- ARP Request: 1 thiết bị sẽ gửi gói tin này nhằm mục đích tìm ra địa chỉ MAC của thiết bị đã biết địa chỉ IP.
- ARP Reply: đây là gói tin trả lời của thiết bị mà có IP ứng với IP trong gói tin request.
- Reverse ARP Request: đây là gói tin có chức năng ngược lại với chức năng của gói tin ARP Request, tức là để tìm IP của thiết bị đã biết địa chỉ MAC
- Reverse ARP Reply: là gói tin trả lời cho RAP request

Cấu trúc của gói tin ARP:

Hardware type (16 bits)	
Protocol type (16 bits)	
Length of hardware address	Length of protocol address
Operator (16 bits)	
Hardware address of the sender	
IP address of the sender	
Hardware address of the receiver	

2.4.2. Công dụng của giao thức ARP

Xét ví dụ sau:



Giả sử máy tính thầy Hiền nằm trong mạng cục bộ có IP là 192.168.0.1 muốn gửi gói tin IP đến cho máy thầy Bình nằm trong cùng mạng có IP là 192.168.0.4, thì quá trình gửi gói tin được thực hiện như sau:

- ❖ Bước 1 máy thầy Hiền xác định địa chỉ IP của máy đích nằm cùng mạng với mình, nó tìm trong ARP cache địa chỉ MAC của máy đích ứng với địa chỉ IP máy đích, nếu thấy nó chuyển sang bước 4b, nếu không thấy nó thực hiện bước 2.

Arp cache là bộ đệm nằm trong bộ nhớ truy cập ngẫu nhiên của máy dùng để chuaws địa chỉ MAC ứng với mỗi IP,

Việc sử dụng ARP Cache giúp giảm thời gian truyền, nhận các gói tin bởi không phải tiến hành gửi gói tin ARP Request nhiều lần.

- ❖ Bước 2: máy thầy Hiền gửi một gói tin ARP request đến tất cả các máy trong mạng LAN
- ❖ Bước 3: máy có địa chỉ IP trùng với IP trong phần TArget protocol address của gói tin ARP request sẽ nhận đó là gói tin gửi đến cho nó và sẽ thực hiện gửi gói tin ARP reply cho máy gửi, còn những máy khác sẽ chỉ nhận gói tin mà không làm gì cả.
- ❖ Bước 4:
 - a. Máy thầy Hiền(192.168.0.1) nhận được gói tin ARP reply từ máy thầy Bình(192.168.0.4)
 - b. Máy thầy Hiền tiến hành cập nhật địa chỉ MAC vừa nhận được vào ARP mapping table.
- ❖ Bước 5: lúc này nó tiến hành gửi gói tin IP với IP đích là 192.168.0.4 và địa chỉ MAC lấy từ ARP mapping table.

Công dụng của giao thức ARP: cung cấp cơ chế ánh xạ IP thành địa chỉ MAC và ngược lại giúp cho các máy tính cũng như thiết bị liên lạc được với nhau trong môi trường mạng

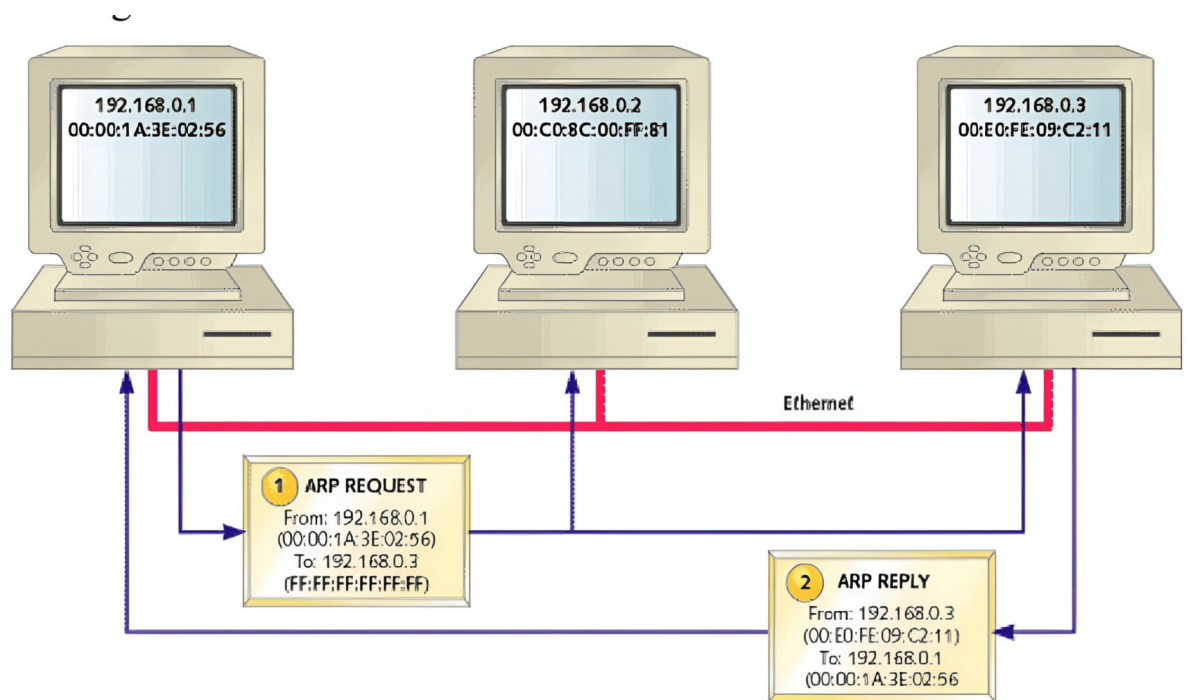
Việc tồn tại 2 loại địa chỉ cùng 1 lúc là do nguyên nhân:

- 2 hệ thống được phát triển độc lập bởi các tổ chức khác nhau.
- Địa chỉ mạng có 32 bit sẽ tiết kiệm đường truyền hơn so với địa chỉ vật lý 48 bit.
- Khi mạch máy thì địa chỉ vật lý cũng mất.
- Trên quan điểm người thiết kế mạng thì sẽ rất hiệu quả khi tầng IP không liên quan gì với các tầng dưới.

Nguyên tắc hoạt động của Arp:

- + Trong môi trường nội mạng: Một Host A muốn gửi 1 gói tin đến 1 Host B cùng mạng. Nếu trong arp cache của nó đã chứa MAC ứng với IP của host B thì nó chỉ việc gửi gói tin IP với header là ip và mac host B. Tuy nhiên nếu ko có MAC host B thì nó sẽ gửi gói tin ARP Request đến toàn miền broadcast của

mạng. Tất cả các host đều nhận được gói tin nhưng chỉ có host B trả lời lại bằng gói tin ARP Reply để khai báo địa chỉ mặc của nó. Có đc MAC, host A sẽ lưu vào arp cache và đóng gói tin IP gửi đi



+Trong môi trường liên mạng: Host a ở mạng A gửi tin cho host B ở mạng B. Nó nhận thấy IP đích của gói tin IP không nằm cùng mạng với mình do đó nó sẽ :

Máy A gửi một ARP request (broadcast) để tìm địa chỉ MAC của port router cùng mạng (X)

- Router ® trả lời, cung cấp cho máy A địa chỉ MAC của port X.
- Máy A truyền gói tin đến port X của Router trong đó có địa chỉ IP của máy B.
- Router nhận được gói tin từ máy A, chuyển gói tin ra port Y của Router. Dĩ nhiên trong gói tin có chứa địa chỉ IP của máy B. Router sẽ gửi ARP request để tìm địa chỉ MAC của máy B.
- Máy B sẽ trả lời cho Router biết địa chỉ MAC của mình. Sau khi nhận được địa chỉ MAC của máy B, Router @ gửi gói tin của A đến B

Làm sao để tạo các gói tin arp:

Các gói tin arp do máy tính tự động tạo ra và quản lý trong quá trình liên lạc giữa các host. Tuy nhiên lập trình viên có thể tạo ra các gói tin arp thủ công (hơi bị phức tạp) Trong windows có thể sử dụng winsock hoặc winpcap.

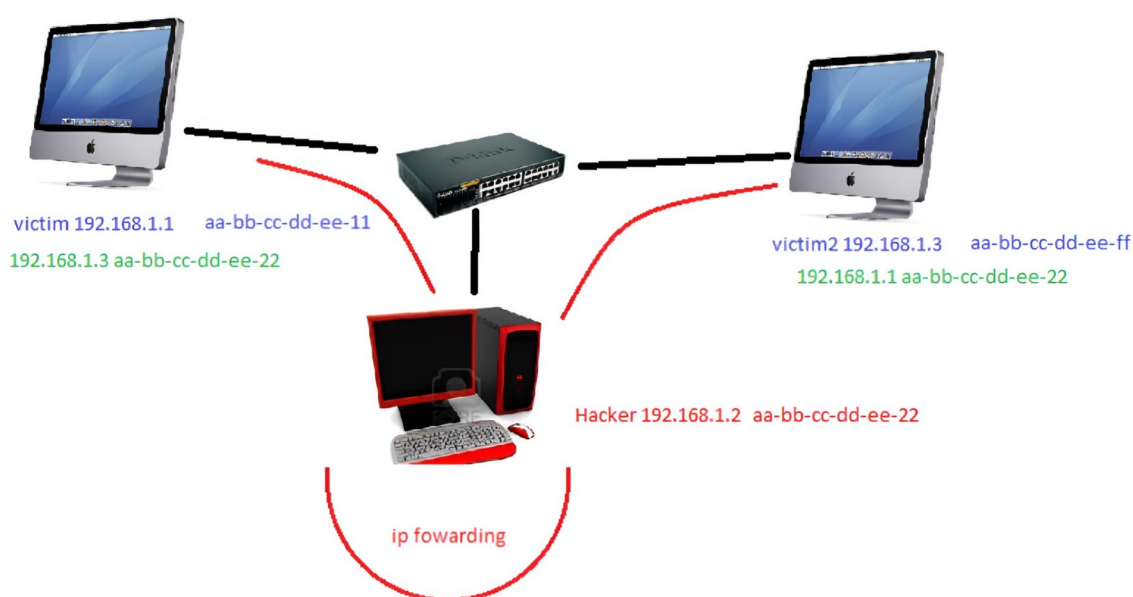
2.4.3. Nguyên lý tấn công:

Mấu chốt để sinh ra việc tấn công giao thức ARP đó là việc không có một cơ chế nào giúp xác thực quá trình phân giải. Một hoạt khi nhận được gói tin arp reply nó hiển nhiên sử dụng địa chỉ mac có trong gói tin arp reply đó cung cấp. Từ đó dẫn đến các kiểu tấn công sau:

- + Man in the middle: hacker (H) cùng mạng nội bộ với host victim (V) muốn nghe lén thông tin của host V trao đổi với host Z (host Z có thể là một máy trong cùng mạng hoặc là router của mạng nếu như host V đang trao đổi với mạng bên ngoài). Các bước của quá trình này như sau:
 - B1: hacker sẽ gửi ARP Reply đến host V với nội dung là địa chỉ MAC của hacker và địa chỉ IP của host Z
 - B2: hacker sẽ gửi gói ARP Reply đến host 2 với nội dung là địa chỉ MAC của hacker và địa chỉ IP của host V.
 - B3: Máy hacker (H) sẽ enable chức năng IP forwarding nhằm giúp cho các gói tin qua lại giữa 2 và V vẫn đến được với nhau.

Lúc này mọi thông tin liên lạc giữa host V và host Z đều đi qua host H và bị Hacker ghi

Phần mềm: cain & able



- + Denial of service:

Host của hacker gửi gói arp reply đến tất cả các host trong máy nội dung là IP gateway và Mac giả. Lúc này toàn bộ các host trong mạng không thể liên lạc được với các mạng khác (internet..)

Phần mềm: netcut

- + Mac flooding: hacker gửi liên tục và không ngừng các gói tin arp reply. switch sẽ xử lý không kịp hoặc xử lý chậm -> làm chậm tốc độ vận tải của mạng và bị đánh cắp thông tin.

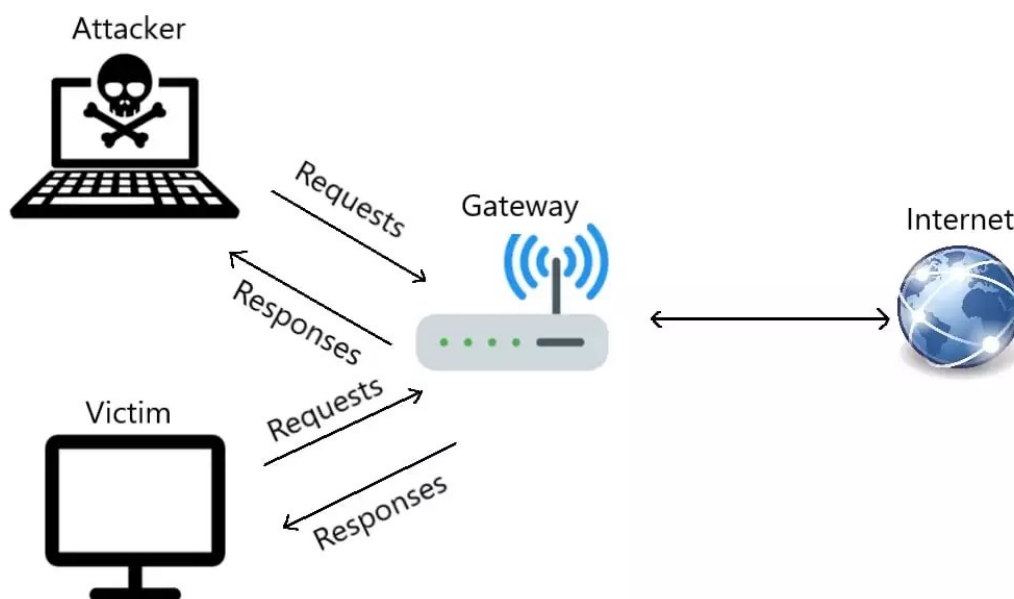
2.5 Giới hạn và điểm yếu của kiểu tấn công ARP Spoof:

Chỉ có những máy nằm trong cùng đường mạng với máy Attacker mới bị tấn công. Các máy nằm khác mạng sẽ không thể bị tấn công bằng hình thức này vì:

- Trong cùng một đường mạng LAN, các máy sẽ thực hiện trao đổi dữ liệu với nhau dựa vào địa chỉ MAC. HostA muốn trao đổi dữ liệu với HostB. HostA sẽ dò tìm trong bảng ARP cache xem IP của HostB sẽ có địa chỉ MAC tương ứng là gì. HostA đóng gói dữ liệu cần truyền với MAC nguồn là MAC HostA, MAC đích là MAC HostB. Sau đó HostA sẽ truyền dữ liệu tới HostB dựa vào MAC đích của gói tin.
- Trong trường hợp HostA, HostB khác đường mạng muốn liên lạc với nhau, ta phải dựa vào địa chỉ IP để truyền dữ liệu và phải thông qua một thiết bị định tuyến, đó là router. HostA sẽ đóng gói dữ liệu cần truyền với MAC nguồn là HostA, MAC đích là router, Gói tin đó sẽ được truyền đến router, router sẽ dựa vào địa chỉ IP đích (IP HostB) và dò tìm trong bảng định tuyến nhằm xác định con đường đi đến HostB. Router có khả năng ngăn chặn các gói tin broadcast

Hình thức tấn công này không thể thực hiện được trong mạng WAN, trên Internet mà chỉ thực hiện được trên cùng mạng LAN

2.6 Phương pháp phòng chống ARP



Để phòng chống tấn công ARP spoofing, bạn có thể thực hiện các biện pháp sau đây: Sử dụng giao thức bảo mật: Sử dụng các giao thức bảo mật như Secure ARP (SARP) hoặc Dynamic ARP Inspection (DAI). SARP sẽ mã hóa thông tin trong gói tin ARP để ngăn chặn việc giả mạo. DAI kiểm tra tính hợp lệ của các bản ghi ARP trên mạng và chặn các gói tin ARP giả mạo.

Cấu hình tường lửa: Cấu hình tường lửa để chặn các gói tin ARP giả mạo từ bên ngoài mạng. Chỉ cho phép các gói tin ARP từ các nguồn đáng tin cậy hoặc từ các thiết bị đã được xác thực truy cập vào mạng.

Sử dụng VLAN (Virtual Local Area Network): Phân chia mạng thành các VLAN riêng biệt để giới hạn phạm vi tác động của tấn công ARP spoofing. Điều này giúp ngăn chặn kẻ tấn công trong một VLAN khỏi việc tác động đến các VLAN khác.

Xác thực mạng: Sử dụng các phương pháp xác thực mạng như 802.1X để yêu cầu xác thực trước khi cho phép truy cập vào mạng. Điều này giúp ngăn chặn kẻ tấn công không xác thực truy cập vào mạng.

Kiểm tra và giám sát địa chỉ ARP: Theo dõi bảng địa chỉ ARP trên các thiết bị mạng và kiểm tra tính hợp lệ của các bản ghi ARP. Nếu phát hiện các bản ghi ARP lạ hoặc không hợp lệ, hãy thực hiện các biện pháp để giải quyết vấn đề.

Cập nhật phần mềm và firmware: Đảm bảo rằng các thiết bị mạng và phần mềm của chúng được cập nhật mới nhất với các bản vá bảo mật. Điều này giúp ngăn chặn lỗ hổng bảo mật đã biết có thể được tận dụng để thực hiện tấn công ARP spoofing.

Giảm quyền truy cập: Hạn chế quyền truy cập của người dùng chỉ vào những thiết bị và tài nguyên mạng cần thiết. Điều này giảm khả năng kẻ tấn công có thể tiến hành tấn công ARP spoofing từ các thiết bị không có quyền truy cập.

Đào tạo người dùng: Đào tạo người dùng về các mối đe dọa bảo mật và cách phòng chống tấn công ARP spoofing. Người dùng cần được hướng dẫn không mở các tệp đính kèm không xác định hoặc không tin cậy, tránh truy cập vào các liên kết không an toàn và sử dụng các phần mềm bảo mật đáng tin cậy.

CHƯƠNG 3: XÂY DỰNG MÔ HÌNH MINH HỌA ARP

KẾT LUẬN

Vấn đề bảo mật an toàn thông tin, nó không chỉ là vấn đề của một người, một doanh nghiệp, một tập đoàn mà nhìn rộng ra thì đó là vấn đề của cả một quốc gia, của cả xã hội.

Việc bảo vệ, phát hiện, ngăn chặn các hành động xâm nhập truy nhập đã, đang và sẽ luôn là vấn đề rất cần thiết không chỉ đối với những chuyên gia an ninh mạng mà còn với tất cả những người tham gia vào mạng máy tính và Internet.

Tuy nhiên, do thời gian có hạn và kiến thức thực tiễn còn hạn chế nên em chưa thể tìm hiểu và trình bày kỹ lưỡng, xác đáng về các vấn đề liên quan. Đây mới chỉ là một phần rất nhỏ mà đề tài có thể cung cấp trong bối cảnh an ninh thông tin hiện nay.

1. **Kết quả đạt được:**

- Hiểu được như thế nào là ARP trong mạng và cách hoạt động của ARP
- Biết thêm về giao thức ARP và tấn công ARP
- Cách thức phòng chống tấn công ARP
- Xây dựng thành công lab mô phỏng ARP trên Cisco Packet Tracer

2. **Hạn chế của đề tài:**

Do thời gian làm đề tài hạn hẹp nên chúng em còn nhiều vướng mắc về nguyên lý tấn công ARP ngoài thực tế.

3. **Hướng phát triển:**

- Tiếp tục nghiên cứu và triển khai thực tế về giao thức tấn công ARP
- Xây dựng lab quy mô lớn hơn và có tính thực tế.

DANH MỤC TÀI LIỆU THAM KHẢO

Tài liệu sách:

[1]

[2]

[3]